

[doc. web n. 10057610]

Provision of July 17, 2024

Register of provisions

n. 444 of July 17, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stazione, president, Prof.

Ginevra Cerrina Feroni, vice president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European

Parliament and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to the

processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the

"Code regarding the protection of personal data,"

which includes provisions for the adaptation

of the national legal system to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter

the "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018, containing

"Provisions for the adaptation of national legislation

to the provisions of Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning

internal procedures with external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of April 4, 2019, published in

G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web

n. 9107633 (hereinafter "Guarantor Regulation No.

1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary

General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the

organization and functioning of the office of the Guarantor for the

protection of personal data, doc. web n. 1098801;

Reporting by Dr. Agostino Ghiglia;

PREMISED

1. The personal data breach and complaints

On XX, the ULSS 6 Euganea Company, hereinafter "Company,"

notified the Authority, pursuant to Article 33 of the

Regulation, of a personal data breach - subsequently supplemented with notes from XX

and XX, XX and XX, XX and XX - concerning a

cyberattack caused by ransomware malware (XX) on the information systems of the Company.

Given the high number of affected individuals involved and the nature of the personal data subject to the breach, it was deemed necessary to investigate the circumstances under which the aforementioned personal data breach occurred, as well as the security measures adopted, through an inspection activity against the Company in the month of XX.

In relation to the same matter, between XX and XX, several requests were received from citizens who, informed of the event that occurred, turned to the Authority.

2. The personal data breach

2.1. The facts

The circumstances relating to the personal data breach were represented by the Company both in the notification to the Authority, made in phases, pursuant to Article 33 of the Regulation, and during the aforementioned inspection activity. In particular, it was found as follows.

2.1.1. The notification of the breach to the Guarantor

With the preliminary notification of XX, the Company declared that it was the victim of a “hacker attack detected by the Company’s information systems at 3:00 AM on XX, which prevents access and availability to certain Company applications (infrastructural, hospital, administrative, territorial) whose precise identification and impact are currently being defined,” specifying that “upon initial analysis, the involvement of the server farm of the peripheral ULSS 6 Euganea located at Via Marconi [...] Monselice (PD) and the Hospital Facility of Camposampiero (PD)” is evident (see, notification of XX, section XX). Subsequently, with a note dated XX, the Company updated the information regarding the breach by providing a copy of the Incident Report from Company XX S.p.A. which indicates that “the attacker accessed the internal network via XX [...]. There are also accesses via the Fortinet VPN, but there is no useful information on the Fortinet logs [...] server XX identified by the name “XX”, on which the malicious program “locker_ce066f3fade586a6_ESXI_Linux” performed encryption operations on the virtual machines and added the extension “lockbit” to the names of such files [...] through the use of domain admin accounts, the attacker used the PSEXEC tool to distribute, on the identified systems, the encryption tool (xxx). This tool disables various security and backup systems and then executes the encryption of the files. [...] The attacker also accessed the VmWare systems; in this case, the root user was used directly and a custom program (locker_ce066f3fade586a6_XX Linux) was employed, distributed by group XX on XX via dark web channels. The tool suspended the various VMs and executed the encryption of the datastores [...] the attacker distributed a custom executable (sender.exe) that is responsible for collecting the files. (“.doc, .docx, .xls, .xlsx, .xlsm, .pdf, .msg, .ppt, .pptx, .sda, .s that fall under the following conditions: those modified in the last 6 months, those older than

one year but modified in the last 6 years. Once collected, these files are sent to an external IP (104.248.142[.]137) via SFTP and WebDav” (see notification of XX, XX).

In addition to what was previously notified, on XX, the Company further updated, based on the “SECOND OPINION REPORT - Cyber Incident AULSS 6 Euganea - v.1.1 of XX” prepared by Yarix s.r.l., the information regarding the breach, stating that “the analysis conducted, although influenced by the lack of some useful elements, allowed for the identification of two different TA (Threat Actors) operating almost contemporaneously in the attack suffered: in the attacked systems, in fact, traces of two different ransomware gangs, XX and XX, were found. [...] the first activities attributable to potential unauthorized access to the infrastructure [...] were traced back to XX, the day on which, based on the available elements, the first access was made from one of the IP addresses associated with the attackers. Starting from XX (...) further activities associated with the attackers were detected, leading to the actual encryption of the data that occurred on the night of XX. In this regard, the detected attack is very peculiar [...] as the two TAs operated on a nearly overlapping timeline, but accessed the systems from two different entry points (VPN on Fortigate device for XX and VPN on XX device for XX) and operated the encryption on different portions of the infrastructure (XX). The checks on the actual exfiltration, unfortunately hindered by the absence of useful data (logs) in some of the analyzed systems, did not allow for absolute certainty to determine whether this occurred, even though the intelligence information gathered by the Cyber Threat Intelligence team nonetheless allowed to ascertain that XX has, at the very least, a list of files compatible with what is present in the AULSS 6 Euganea systems.” It was also represented that “this short list, which lists the potential exfiltration of approximately 17,000 documents containing personal and non-personal data, is currently under constant review by the Information Systems of AULSS 6, in order to confirm the actual correspondence of the files in the possession of the TA with the corporate ones and to subsequently provide the precise communication to the interested parties, also providing tools to support their rights and freedoms. A detailed analysis of these potentially exfiltrated documents has been initiated by a multidisciplinary task force, appointed by the Company Management and specifically trained [...]”. The Company, “having examined the second opinion report from Yarix, and evaluated the list of unexamined artifacts, intervened with the contractors involved in the services related to the security of the company's infrastructural perimeter (services attributable to supplier XX spa) and made available to Yarix s.r.l. seven machines for the purpose

of completing the analysis activities. Below are the findings of Cyber Threat Intelligence as per the report from Yarix s.r.l. of XX, an integral part of the aforementioned report:

“During the Cyber Intelligence activities, the Cyber Threat Intelligence team of Yarix (YCTI) identified through the undercover profiles of its analysts, the compromise of three hosts with access to the following internal portals belonging to the AULSS6 perimeter: from the initial analyses conducted on the identified data, it is evident that the information was collected by three info-stealer instances of the Redline family active on the machines for a certain period. The transmission of information to the C&C; occurred respectively on the following dates: Host 1: XX: XX: XX. The date of transmission of the information by the malware does not demonstrate that the credentials are still valid or that they were used on that specific date: it is possible, for example, that the malware retrieved and sent to the C2 server all the credentials saved in the browser up to that moment. Host 1 contains one of the credentials identified during the incident analysis of XX as a VPN entry point for XX (user XX), and it is therefore plausible to assume that it was the subject of trade for the purpose of the attack itself” (see notification of XX, XX). As further integration regarding the publication of data by group XX, on XX the Company intended to attach the “Cyber Intelligence Report” of XX and the “SECOND OPINION REPORT - Cyber Incident AULSS 6 Euganea - rev. XX” prepared by Yarix s.r.l. (see notification of XX, section XX). Finally, in a note dated XX, the Company highlighted what is present in the “SECOND OPINION REPORT - Cyber Incident AULSS 6 Euganea - rev 1.3 of XX” prepared by Yarix s.r.l., in the part where it was reported that “on XX, following some further details provided during the analysis [...] a LOG collection system FortiAnalyzer (FAZVM64) was identified and acquired at the Padova Colli site, which was in production during the incident [...] the analyses allowed for the detection of traffic towards the exfiltration IP from the firewall FW-SCRO14-DC. Specifically, during the time frame between 00:52:10 and 02:12:28 on day XX, outgoing traffic was detected from 18 clients belonging to the ULSS17 domain [...]; the traffic analysis allowed for the detection of a data transfer of approximately 700 MB” (see notification of XX, XX).

2.1.2. Inspection Activities

During the inspection activities, the Company confirmed “the analysis conducted by YARIX with particular reference to the timeline of the document ‘Second Opinion Report - Cyber Incident AULSS 6 Euganea’ version 1.3 - XX”, specified that “the first accesses of the malicious actor, via VPN, date back to the month of XX, subsequently the threat actor XX proceeded with the typical actions of a cyber kill chain”; that “on XX at 2:37 AM, the help desk, following the receipt of a report of malfunction in the ticketing system, activated the available system support from the infrastructure management

provider. Subsequently, the company XX of the XX group, specialized in cybersecurity, was involved” and that “the ULSS, not having system administrators among its employees, requested a second opinion regarding the security incident from YARIX, a sector leader, for its position of impartiality and absence of conflict of interest” (see minutes of XX, page XX).

Regarding the scope of the violation in relation to the healthcare and administrative accounting applications, the Company stated that “the administrative accounting applications were not involved and the virtualization console of the healthcare applications was encrypted, as well as part of the workstations. Despite the complexity of the Company’s technological infrastructure, composed of numerous and different physical and virtual devices, biomedical equipment, and equipment for examinations in various hospital specialty areas, it was possible to restore business operations in a short time. This was achieved with a service continuity plan, continuous assessment of priorities and the status of activities carried out by the various working groups and crisis units, and with the involvement of all available human resources.” The owner also intended to clarify that “[the published data] were not exfiltrated from the databases but came from the workstations of employees who had saved personal documents or work lists (e.g., admissions, discharges) locally or patient records sometimes in draft or incomplete form and not cataloged, contrary to the instructions [...] which provided exclusively for the use of ‘shared folders’ or dedicated systems”; that “the institutional website of the Company has always been operational” and that “the provision of services to users and the delivery of healthcare services did not suffer any interruption as the procedures provided for in case of disaster were adopted. In any case, following the restoration of the technological infrastructure, all data related to activities carried out in emergency mode were transferred” (see minutes of XX, pages XX and XX).

As for the number of individuals whose health data were involved in the attack, the Company stated that “the task force was able to precisely delineate the perimeter of the violation in terms of the quantity of personal data, types of personal data, and types and number of individuals, noting lower numbers than initially projected at the start of the data breach (n. individuals 9,520, instead of 23,886 – n. files 5,763 instead of 32,555)” (see notification of XX, section XX). Finally, the Company provided an integration to the technical report of the task force of XX attached to the notification of XX, stating that the number of individuals involved “is substantially lower” (see note of XX to resolve the reservations of the inspection of XX, attachment XX).

2.2. Measures in place at the time of the violation

2.2.1. Notification of the violation to the Authority

Regarding the measures in place at the time of the violation, the Company stated:

- that “AULSS6 derives from the unification of three former ULSS, each with its own different information system; the most significant action was the consolidation, unification, and securing of a single new domain AULSS6 Euganea and the progressive cessation of the old domains and non-unified systems; perimeter security is ensured by the use of IPS, antivirus, web filtering, certification inspection on dedicated systems. Only defined and authorized software is installed on workstations in the AULSS6 Domain, and access with Local Admin is not permitted. The usage modalities of the PDL and more generally of IT tools” are defined “by company regulations. The setup of machines (servers and PDL) occurs through standard templates stored offline and accessible only to authorized personnel. Access to servers is granted exclusively with administrative accounts and to the PDL only upon authorization. Administrative accounts have passwords XX (XX). For control and monitoring of workstations, the XX system is active both client and server, while for inventory purposes, the XX system is used; the log management system (XX managed by a specialized company) is already active on the most relevant systems. Regarding backups, daily full and incremental backups are active on all physical, virtual systems, and databases: this has indeed allowed for rapid and secure restoration. Concerning vulnerability assessment, a service with a specialized company is active, executed at least monthly with subsequent corrective actions reported to the main actors to intervene to overcome the reported vulnerabilities. For all new workstations that support the functionality, the anti-malware scanning function for removable media has been activated

as well as the filtering of email messages and web traffic through regional Google Cloud services. In particular, backups are managed with the following systems: XX with the related backup policies (daily incremental, weekly synthetic) for the Database XX, the Backup occurs on the XX platform (Daily Full Backup and hourly archive log). With Resolution No. 709

of XX, the Security Program Document was adopted, which outlines an intensive improvement plan aimed at raising the average and maximum security measures, with particular reference to AgID Circular 2/2017 and FNSI, including a training plan in collaboration with the DPO for all personnel of the information systems”;

- to have “already undertaken, starting from 2018, targeted training paths aimed at management and staff, intended to enhance and strengthen the knowledge and diligent behaviors to be implemented in the field of privacy, data protection, and information security. This is due both to the advent of the EU regulation under the GDPR, and in light of the reorganization of the Regional Health System, as per regional law no. 19/2016, effective from January 1, 2017, which provided for the unification of the health companies AULSS 15, 16, and 17 into AULSS 6 Euganea and led to the initiation of a new corporate information system and personal data management, as well as the definition of a new corporate privacy system”;

- that “has implemented and keeps updated all organizational measures under the GDPR regarding appointments to authorized persons pursuant to Articles 29 GDPR and 2-quaterdecies CP, to the data controller pursuant to Article 28 GDPR and in relation to the designation of the DPO, as well as through the preparation of data breach procedures and risk assessment, applied during the incident in question” (see notification of XX, section XX, point XX).

2.2.2. Inspection Activities

Regarding the computer authentication procedures used in the context of VPN access and the workstations in place at the time of the breach and the password policies provided for the different types of users, the Company, during the inspection activities, stated that:

- “at the time of the personal data breach, multi-factor authentication procedures for access to the network and systems managed by the Company via VPN were not provided”;

- “the ULSS had prepared a regulation for remote access [...] and that the XX had approved a ‘Security Program Document’ to enhance security measures and align them with the minimum AgID measures [...] in this document, among other things, the measure of two-factor authentication for VPN access was provided”;

- “non-privileged users are registered in the Identity Management (IM) platform (XX) of supplier XX and then in the Active Directory, the credentials consist of XX. The personnel performing administrative functions have two accounts, one non-privileged and one with administrative privileges (XX) and connect to the systems via RDP or SSH”;

- “non-administrative accounts have the following password policy: XX. Compliance with the policy is ensured by the controls of the IM platform. Privileged accounts have a password policy of XX with the same rules”;

- “the ULSS, following the unification, had undertaken a path of normalization of infrastructures (over XX servers), workstations (about XX), domains, and policies, which was interrupted due to the pandemic”;

- “the former ASL 15 and 17 were equipped with obsolete infrastructures”;

- “the old firewalls of the former ASLs and the old VPNs were still present to ensure operational continuity, normally updated by the technicians, except in specific and justified cases” (see minutes of XX, pages XX, XX, and XX).

In this regard, the Company then confirmed that “at the time of the attack, the logic for managing the passwords of accounts with elevated privileges implemented on domain XX complied, in accordance with AGID best practices, with the security posture rules detailed below: XX” (see note of XX to clarify

the findings of the inspection of XX, see particularly, annex no. XX and also XX and XX).

With reference to the security measures in place at the time of the personal data breach, related to network segmentation, the Company stated that “the servers of the former ASLs 16 and 17 were located on a dedicated VLAN different from the one where the workstations were located, and a new environment was being prepared starting from the 3 Data Centers of the 3 ASLs” (see minutes of XX, page XX).

Regarding the technical and organizational measures adopted to ensure the availability and resilience of the systems and processing services, as well as the timely restoration of the availability and access to personal data in the event of an incident, the Company stated that:

- “there was a system monitoring system but not a control room”;
- “the SGM service for operation, maintenance, and management of devices did not include automated analysis and monitoring tools for security events”;
- “the weekly sending of VPN XX logs to the box XX was not active because, during the activities following the unification and consolidation of the systems of the 3 ASLs, a reconfiguration of the email communications of the devices towards a single collection point was underway, and therefore, it is hypothesized that the aforementioned log was involved in this migration phase”;
- “it had been using the backup system XX since XX” (see minutes of XX, pages XX and XX).

Subsequently, the Company clarified that “at the time of the attack, heterogeneous and differentiated rules were operational for each firewall in relation to the storage capabilities of the devices and the traffic logging rules. Regarding the retention of logs, related...

of the current regulatory framework; b) implementazione di un sistema di gestione della sicurezza delle informazioni (ISMS) conforme agli standard ISO 27001; c) formazione continua del personale in materia di sicurezza informatica e protezione dei dati; d) revisione e aggiornamento delle procedure di accesso ai sistemi informatici e di gestione dei log; e) attuazione di controlli di accesso più rigorosi e monitoraggio delle attività degli utenti; f) creazione di un piano di risposta agli incidenti che preveda procedure chiare per la gestione di eventuali violazioni; g) audit regolari della sicurezza informatica e delle pratiche di protezione dei dati; h) collaborazione con esperti esterni per la valutazione delle vulnerabilità e la gestione del rischio” (v. nota del XX).

2.3.2. Comunicazione agli interessati

In merito alla comunicazione della violazione agli interessati, l'Azienda ha dichiarato che: “è stata effettuata una valutazione dell'impatto della violazione sui diritti e le libertà degli interessati, e si è ritenuto necessario informare tempestivamente gli stessi, fornendo informazioni chiare e comprensibili riguardo alla natura della violazione, alle conseguenze potenziali e alle misure adottate per mitigare i rischi” (nota del XX).

2.3.3. Collaborazione con le autorità competenti

L'Azienda ha inoltre confermato di aver collaborato attivamente con le autorità competenti, fornendo tutte le informazioni richieste e seguendo le indicazioni ricevute per garantire una gestione efficace della situazione e la protezione dei dati degli interessati (nota del XX).

2.4. Conclusioni

In conclusione, l'Azienda ha evidenziato che, nonostante l'incidente, sono state adottate misure tempestive e adeguate per contenere i danni e garantire la continuità dei servizi. Si è impegnata a migliorare ulteriormente le proprie pratiche di sicurezza informatica e protezione dei dati, al fine di prevenire simili incidenti in futuro e tutelare i diritti degli interessati (nota del XX).

the company, for which activities for the review of organizational processes resulting from the merger of the three former Padua health companies (ULSS15 - ULSS16 - ULSS17) and the managed treatments are still ongoing, as well as within the framework of the continuous improvement path, as provided for and represented in the performance plan 2022-2024 and in the directive document for the year 2022, the necessity to redefine the company privacy system within the Personal Data Protection

Management System (SGA PDP) has been recognized, and to establish a multidisciplinary support team in order to give greater impetus to the undertaken path and ensure operational support capable of underpinning the data protection framework, demonstrating the capabilities and attitude of the entire organization towards the enhancement and protection of the informational heritage, ensuring the monitoring and continuous improvement of processes and procedures. The team has been assigned functions of analysis and support to the personal data protection office (formerly the privacy office), in coordination with the DPO. The aim is to guarantee multidisciplinary support so as not to lose sight of the protection objective and to maintain the efficiency over time of the set of security measures adopted, improving it if and when necessary.

b) Adherence to PDR 43:2018: The Management has activated the process to achieve certification of adherence to the “Guidelines for the management of personal data in the ICT sector according to EU Regulation 2016/679” with the aim of improving actions for the correct processing of personal data of the Personal Data Protection Management System, laying the foundations for certification mechanisms as hoped for by Article 42 of European Regulation no. 679/2016.

c) ISO 9001:2015 and 27001:2017 Certifications: The Management has initiated the process for adherence to the quality management model for information security in order to redefine processes and tools related to information security and obtain ISO 9001:2015 and 27001:2017 certification following the alignment of the activities of information systems with the indications provided by the regulations on personal data protection. This is to allow the safe free circulation of personal data within the SGA PDP.

d) Training: diversified training paths have been intensified for all company personnel as well as for the multidisciplinary team” (see notification of XX section XX, point XX).

2.3.2. Inspection Activities

During the inspection activities, the Company stated that “following the breach, a multi-factor authentication procedure was activated at XX for access to the network and systems managed by the Company via VPN, with the second factor XX” and that “instructions for activating the VPN with MFA were provided to employees via email” (see minutes XX, page XX). Furthermore, the Company represented that “following the suggestions of YARIX, contained in the second opinion report, a structured SIEM was activated that collects various logs in the process of consolidation, first with temporary assignments and subsequently in the new contract in force with XX,” that “the XDR system of company XX has been adopted” and “starting from the end of XX, a series of security measures have been activated including the XDR tool of XX, monitored 24/7 by the SOC of YARIX, to protect endpoints, for response and countering threats; a SIEM system for log collection to monitor all security events; an analysis service for collecting intelligence information from open and closed sources (OSINT and CLOSINT) in order to identify any data exfiltrations, account and user compromises as well as other potential threats related to the perimeter agreed with the ULSS (XX)” (see minutes of XX, pages XX and XX).

Regarding organizational measures, the Company highlighted that “the review process of the procedures already underway has accelerated, leading to the definition of a Personal Data Protection Management System (SGA PDP) [...]. Following the incident, the network of referents that dealt, among other things, with procedures and clinical risk, has acquired the additional competence of data protection with appropriate training to establish a field observatory both to intercept anomalies and to better regulate new projects and activities that may impact data protection. The network currently consists of XX people. A multidisciplinary team has also been established (data protection skills, ICT security, medical, human resources, etc.), trained with an 80-hour course – with specific modules on topics such as consent, scientific research, medical apps, medical devices, artificial intelligence - in addition to the annual training plan for all employees which already included topics on data protection and ICT security [...]. It has also adopted the tool XX which, in addition to providing all the procedures and documentation necessary to inform employees, collects reports from the network of referents and will soon be extended to all personnel, for a quick and centralized collection of data from individual units, channeled at the company level towards the DPO and strategic management. This tool is

therefore used for raising awareness among staff and distributing documentation of all updated procedures that employees must review. Reports collected through this tool are analyzed by the Quality office which, if necessary, involves the multidisciplinary team and the DPO," that "a privacy office has been established, separate from the DPO, which deals, among other things, with comunicato di aver sporto denuncia presso l'Autorità Giudiziaria.

3. Conclusioni

In conclusione, l'Azienda ha dimostrato di aver intrapreso tutte le misure necessarie per gestire l'incidente di sicurezza informatica, inclusa la comunicazione tempestiva agli interessati e l'attivazione di un'unità di crisi. Nonostante il rischio elevato per i diritti e le libertà delle persone fisiche, l'Azienda ha adottato un approccio proattivo per mitigare gli effetti dell'incidente e garantire la protezione dei dati personali.

4. Raccomandazioni

Si raccomanda all'Azienda di continuare a monitorare la situazione e di fornire aggiornamenti regolari agli interessati riguardo a eventuali sviluppi. Inoltre, è fondamentale che l'Azienda completi il percorso di certificazione ISO 27001 e UNI PdR 43:2018 per rafforzare ulteriormente le proprie misure di sicurezza e compliance.

5. Allegati

- Verbale dell'XX, pag. XX
- Notifica del XX, sez. XX, punto XX
- Comunicazioni ex art. 34 del GDPR inviate ai dipendenti

Data: XX

Firma: _____

Nome: _____

Posizione: _____

contacted the available numbers to obtain information regarding access to documents. It is specified that this company has necessarily had to manage and adopt two distinct modes of communication to the interested parties involved in the publication of personal data [...], whereas, for the remaining number of interested parties not reachable by personal communication [...] it was deemed appropriate to proceed with a generalized communication pursuant to art. 34, letter c) of the GDPR [...] through the posting of appropriate signage in transit areas and with higher foot traffic (...). This choice will allow the Company to redirect resources towards a development plan (training and structural) of the Personal Data Protection Management System that had been delayed by the events related to COVID that heavily impacted all our facilities. Furthermore, the same communication was published on the company website (XX) at the following link: XX. The generalized communication will be highlighted for 6 (six) months from the date of dissemination" (see notification of XX, section XX point XX and XX points XX and XX). During the inspection activities, the Company confirmed "the actions taken to mitigate the negative effects on the interested parties regarding the communication, pursuant to art. 34 of the Regulation, already reported in the notification of XX and the subsequent integrations, specifying that very few specific requests were received from the interested parties through the contact channels set up by the Company (DPO mailbox and dedicated toll-free number), despite the information being made available through signage posted in all hospitals, clinics, and transit locations as well as the intense media campaign developed in the period immediately following the incident" and that "the various press releases [...] were also prepared [involving the authority] judicial involved in the investigations" (see minutes of XX, page XX and of XX page XX).

3. Assessments of the Department on the processing carried out and notification of the violation referred to in art. 166, paragraph 5 of the Code In relation to the case described, the Office, based on what was represented by the data controller in the notification of the violation and what emerged during the inspection activity, as well as subsequent assessments, notified the Company, pursuant to art. 166, paragraph 5, of the Code, the initiation of a procedure for the adoption of the measures referred to in art. 58, paragraph 2, of the Regulation, inviting the aforementioned data controller to submit defensive writings or documents to the Authority or to request to be heard by the Authority (art.

166, paragraphs 6 and 7, of the Code; as well as art. 18, paragraph 1, of law no. 689 of 24/11/1981). In particular, with act no. XX of XX, the Authority deemed that the Company processed the personal data in question in violation of the principle of “integrity and confidentiality,” as per art. 5, paragraph 1, letter f), of the Regulation and failing to implement technical and organizational measures to promptly identify a breach, as well as to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of processing systems and services, in violation of art. 32 of the Regulation. The Company submitted its defensive memoranda, pursuant to art. 166, paragraph 6, of the Code. In particular, with note of XX, it stated that: “the Company was established on January 1, 2017, as a result of the healthcare reform of the Veneto Region enacted by Regional Law No. 19 of October 25, 2016 (“Regional Law”). As a result of the Regional Law, as subsequently integrated and amended, the former ULSS n. 16 of Padua changed its name to ULSS 6 Euganea, incorporating the abolished ULSS n. 15 Alta Padovana and ULSS n. 17 Este”; “the Company is currently a large and complex entity, serving a user base of over 920,000 patients, belonging to 101 municipalities, over a territorial extension of 2,127 square kilometers, with a density of about 437 inhabitants/square kilometer, thus being the most populated healthcare company and with the highest density in the Veneto Region”; “the Company is organized into 5 health districts (3 central districts in Padua and 2 districts for Alta and Bassa Padovana); by virtue of the aforementioned Regional Law, the Company, a provincial entity, has 4 spoke hospitals: 2 hospitals in Alta Padovana (...), 1 hospital in the center (...) and 1 network hospital in Bassa Padovana (...) as well as a provincial rehabilitation facility”; “as of XX, the Company had 7,166 employees, including 1,089 doctors and veterinarians, 43 other executives in technical, professional, and administrative roles, 3,824 nurses, 1,530 healthcare operators (OSS and OTAA), and 680 administrative staff”; “the Regional Law also established the Governance Entity of the Veneto regional healthcare, called “Azienda Zero,” also outside the scope of the Company, to which the Veneto Region has assigned functions related to the management of technical-specialist activities, including, in art. 2, paragraph 1, letter g) no. 6 functions related to “the management of technical-specialist activities for the system and for the entities of the regional healthcare service such as, the IT infrastructure, connectivity, information systems, and data flows in a perspective of homogenization and development of the ICT system”; “before the reform carried out by the Regional Law, the two former ULSS15 and former ULSS17 each had their own IT system, governed and managed by a Complex Operational Unit (UOC) headed, respectively, by a Manager. data personali”;

“inoltre, si evidenzia che l’Autorità Garante ha l’obbligo di concludere il procedimento entro il termine di 90 giorni dalla ricezione della notificazione, come stabilito dall’art. 33, comma quarto, del Regolamento. Pertanto, la durata complessiva del procedimento ha superato i termini previsti dalla normativa vigente”;

“in conclusione, si chiede che venga riconosciuta l’illegittimità della sanzione irrogata, tenuto conto delle circostanze sopra esposte e della necessità di garantire il rispetto dei diritti fondamentali e delle garanzie procedurali previste dalla legge”.

personal data (Articles 33 and 34 of the GDPR)” (see table B, part 1). It is therefore believed that the sanctioning procedure initiated with the Communication is fundamentally flawed due to the abnormal time lapse between the sending of the notification of closure of the data breach and the initiation of the same”;

on the merits of the issue “allow us to contest the reconstruction made by this Illustrious Authority as it is based exclusively on the partial information acquired during the inspection activity, during which the individual who, at the time of the violation, was the Head of the Company’s Information Systems was not present, as he had resigned, and who, prior to the incident, had been responsible for activities

related to securing the networks. (...). What is stated in the minutes of XX on page 3 regarding the VLAN must therefore necessarily be supplemented with the statements subsequently acquired from the Company by Eng. (...) who, as Head of the Information Systems, had managed this aspect at the time”;

in addition to what was stated during the inspection activities “despite the difficulties related to the Unification mentioned in the first paragraph, at the time of the incident, Eng. (...) states, with confirmation from his then collaborators (...), that “as of XX, also due to the available funding, the following activities had been completed: - definition of the guidance plan for the entire Company, configuration and segmentation of the new Datacenter in Camposampiero; - commissioning of the new AULSS 6 domain. Furthermore, the following were in an advanced stage of implementation: the configuration of various applications on the new domain with simultaneous migration from the old datacenters, updating and insertion into the network in the various defined VLANs”;

“although the partitioning plan on all subnets of the Company’s locations was not completed, it should be clarified that at the time of the incident there was in any case a separation via VLAN of all the main data communication flows to and from all datacenters to the various locations. Moreover, it is possible to assert with reasonable certainty that even the completion of the segmentation and segregation, which was already underway, would not have been able to prevent the occurrence of the incident, for the reasons indicated below and for the nature of the incident itself”;

“VLANs certainly represent a method for segmenting a broadcast domain into multiple smaller domains. At OSI layer 2, each VLAN contains only the traffic of the devices belonging to that VLAN. With VLANs, workgroups can be created with devices located physically anywhere on a network, which can, however, communicate as if they were on the same physical segment, as indicated in the diagrams provided below for clarity of exposition. It follows that a user who possesses administrator credentials for a computer network can access the “management VLANs” that are used to configure and maintain VLANs in complex environments and, therefore, is able to connect to them, modify them, and ultimately bypass them as a security measure to reduce the impact of an attack such as that carried out by the two attackers in the incident in question”;

“such reflections are also confirmed by the statement of XX, which specifies: “a system administrator, as the attacker had become on XX, having the ability to perform lateral movements between the server and DB systems could access the various VLAN networks making this security measure less effective for this case””;

“the attacker initially acted with non-privileged user accounts and subsequently with legitimate system administrator accounts, in a relatively short period of time. Due to the nature of the role assumed by the attacker in the final phase, therefore, the completion of the segregation and segmentation process would not have constituted an additional security measure capable of preventing what occurred in practice. Nevertheless, as clarified during the inspection, it is confirmed that the segregation and segmentation process had been widely initiated as soon as the necessary financial resources were allocated and, in any case, before the incident, and that this process was completed subsequently to minimize the impact of cyber attacks of a different nature than that which occurred”;

“as for the contested absence of two-factor authentication for the VPNs [...] with reference to the VPNs accessible with non-privileged user accounts (thus non-administrator type), in this case used by the attackers during the period between XX and XX [...] it is noted that at the time of the incident, two-factor authentication was not even a measure provided at the maximum level by AGID in the “Minimum ICT Security Measures for Public Administrations. (Directive of the President of the Council of Ministers August 1, 2015)” of April 2017, in force *ratione temporis*”;

“with reference to the VPNs accessible with system administrator accounts, whose first access occurred only on XX, the cited AGID Security Measures provide for two-factor authentication only for “privileged accounts and administrative rights,” classifying the related measure as a “High” level. Moreover, it is reiterated that the implementation of two-factor authentication was underway to ensure the maximum levels referred to in the cited AGID security measures, given that the Company had

requested this from CRITE two years prior to the date of the incident and had only received partial authorization in XX. Following the authorization,

The Company had promptly taken action to implement this measure, included in the security program document of XX, which, however, required a timeline for implementation such that it was not in effect at the time of the incident. It is specified that, in any case, as of the date of the incident, although the MFA (Measure 5.6.1) had not yet been implemented, the alternative measure of high password robustness for administrative accounts (Measure 5.7.1) was active, to be used “when multi-factor authentication is not supported,” expressly indicated as equivalent by the aforementioned security measures of AGID (see attachment XX of the defensive writings of XX). Furthermore, it is worth noting that subsequent to the incident, all active VPNs were equipped with MFA;

“what is relevant for the timely action of the data controller, who is required to notify the Supervisory Authority of the breach within 72 hours, is the moment from which he became aware of the disclosure or unauthorized or accidental access to personal data (art. 33 par. 1 of the Regulation). In this regard, it is also necessary to refer to Recital 87 of the Regulation” and the Guidelines on the notification of personal data breaches under Regulation (EU) 2016/679, adopted on October 3, 2017, Amended Version adopted on February 6, 2018. WP250;

“the ‘suspicion of a breach’ exists only in the presence of elements suitable to suggest (i.e., without reasonable certainty) the ‘disclosure or unauthorized or accidental access to personal data,’ highlighting that in the aforementioned Guidelines of 2017 it was ‘clarified that in order to promptly identify a breach, it is advisable not to underestimate, but rather to analyze, the suspicions of the same, although the measures to remedy it require that the data controller is effectively “aware” of the breach. Consequently, the data controller must

“have internal procedures in place to detect a breach and remedy it. For example, to detect certain irregularities in data processing, the data controller or the data processor can use certain technical measures such as data flows and log analyzers, from which it is possible to define events and alerts by correlating any log data”;

“in this context, the data controller must adopt technical and organizational measures (pursuant to art. 32 of the Regulation) suitable for promptly identifying, handling, and reporting a breach. Indeed, as can be seen from the reading of the Second Opinion conducted by Yarix (“Second Opinion”), the attackers during the period XX - XX accessed the Company’s systems by exploiting VPNs with non-privileged user accounts [...]; the first access to the VPN with system administrator privileges occurred on XX at 21:25, and therefore just a few hours before the actual knowledge of the breach materialized. The Company, at the time of becoming aware of the incident (XX), had technical and organizational measures in place suitable for promptly identifying, handling, and reporting a breach of the security perimeter of the network through unauthorized or forced VPN accesses. However, such measures could not allow for the evaluation of accesses made prior to the manifestation of the breach as symptomatic of a breach, as they were made using valid access credentials (...); only after the manifestation of the breach on XX was it possible to reconstruct that the accesses in question were actually made by individuals who had unlawfully obtained those valid credentials”;

“the measures adopted by the Company for the timely identification of the breach consisted, in addition to what had already been previously stated in the records, also of activities entrusted to company XX, by virtue of the Consip Agreement ‘Management and Maintenance Service of IP Systems and Workstations’ (SGM). In particular, XX [...] was to independently carry out a series of activities aimed at managing security devices [...]; the activities covered by the Consip Agreement and entrusted to XX are in line with the indications of the Working Group regarding the timely identification of a breach, including ‘For example, to detect certain irregularities in data processing, the data controller or the data processor can use certain technical measures such as data flows and log analyzers, from which it is possible to define events and alerts by correlating any log data.’ In this regard, it is worth noting how XX declared to the Company that it had carried out the aforementioned contractually stipulated activities, and in particular: ‘a) 24/7 monitoring service, intervention, and proactive analysis also for issues of cybersecurity carried out through the systems used for the management and maintenance of

the Administration's devices, particularly for firewall devices, routers/switches, and servers; b) periodic analysis of logs for the search for anomalous events (access attempts, anomalous traffic, viral attacks, policy violations, etc., and any potentially harmful event). That said, it is reiterated that the monitoring systems in use were configured for alerting in case of operational anomalies of the devices covered by the agreement or interruption of their functionalities and/or degradation of performance (point a.) while the policies used for the search for anomalous events (point b.) provided warnings for XX;

"in this case, the attacker initially acted with non-privileged user accounts and subsequently with legitimate system administrator accounts, within a relatively short period, with limited attempts to..." access (no brute force), from countries not listed in the black list and without causing operational anomalies to the monitored systems (no denial of service was detected in the period preceding XX). This situation would likely not have been detected even by advanced SOC's that were not equipped with machine learning systems and Artificial Intelligence algorithms capable of detecting significant deviations from the "normal" behavior of each user, device, and/or subnet of the organization (...); only after further investigations, on XX, the Company Yarix, to which the Company commissioned the Second Opinion, was able to consider the previous accesses as of XX as activities related to the incident;

"taking into account the modalities of the incident and the activities carried out to prevent and identify it, as well as the historical-technological period different from the current one (the incident occurred at the end of the year XX), the Company cannot be reproached in terms of the absence of measures suitable for the timely identification of the incident";

"among the parameters that data controllers are called to consider in identifying suitable security measures for the specific processing, the 'state of the art' and the 'costs of implementation' are relevant, pursuant to Article 32 of the Regulation. Regarding the 'state of the art', it must be considered that the standard defined by the AGID Security Measures of 2017 constituted an undeniable reference parameter for a public administration like the Company to evaluate, with the knowledge of that time, the adequacy of the security measures in place at the time of the breach. Furthermore, it is not clarified in the notice of violation what additional security measures the Company should have adopted in order to prevent the incident that occurred. Even the possible availability of additional 'firewall logs', as noted in the Communication, would not have allowed for earlier detection of the breach, at most it would have attempted to trace the identity of the attackers, an activity that is nonetheless irrelevant for this Illustrious Authority";

"on the contrary, as has been demonstrated, even in the presence of a control room monitoring data flows, it would not have been possible to identify the breach earlier. In fact, the attack occurred using the credentials of a non-privileged user and, moreover, accessing not from countries in the so-called black list. Probably, such a structured attack would only be identified earlier by a modern control room capable of processing data also through artificial intelligence application tools. But, it is reiterated, for the purposes of this proceeding, the 'state of the art' of 2021 must be taken into account. To what has been said, it must necessarily be added that evaluations on the 'costs of implementation' fall outside the Company's sphere of competence and that, by virtue of Regional Law, they are the exclusive competence of the CRITE. The Company, in fact, had repeatedly requested to implement additional security measures, but the CRITE had not endorsed such requests [...] not allocating additional funds (...);

"regarding the violation of the principle of integrity and confidentiality, the reconstruction made is completely contested, as the Company at the time of the incident was in line with the AGID Security Measures and it is not proven that additional, but not better specified, security measures would have prevented the violation that occurred or would have allowed the Company to notice it earlier. Furthermore, the Company was not in a material position to implement technical measures different from those previously approved by the CRITE, under penalty of incurring violations of a fiscal nature (and even of a criminal nature);

"the number of affected individuals is 9,520 (of which 8,535 affected by health data violations and 985

affected by violations of personal, contact, access, and identification data), out of a total of more than 920,000 patients belonging to the Company. However, [...] from the review of the documents subject to exfiltration, it emerged that the actual number of affected individuals, to whom the health data refers, is substantially lower, due to biases attributable to the artificial intelligence software used. It is confirmed that the personal data exfiltrated and published under examination refer to documents present on PCs and not on corporate servers, in disregard of existing corporate policies already on record”;

“the Company was the victim of a hacker attack on its information systems carried out by two distinct threat actors – XX and XX – who acted almost simultaneously. The Company had adequate security measures, both technical and organizational, for the historical-technological period in which the violation occurred (XX), circumstances that exclude any form of fault on the part of the Company, even in the mildest and potential form. At most, it is believed that the Company may be attributed a good faith error, having operated in compliance with the sector regulations in force at the time and having only later realized that it was necessary to integrate these measures, as already planned”;

“at the time of the incident” all the security measures identified by the AGID were “operational within the Company and (...) it had (...) proactively activated to make further improvements, although not required by the sector regulations in force at the time of the facts” (...), the error, if there was one, was unintentional, as it could not have been prevented by the Company, despite the (extra)ordinary diligence shown in seeking to implement increasingly advanced security measures,” highlighting the “extraordinary effort.

in consideration of the risks presented by the processing, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, as appropriate: (a) the pseudonymization and encryption of personal data; (b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; (c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident; (d) the process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing”;

5. Conclusions

Based on the findings of the investigation and the information provided by the Company, it is concluded that the Company has taken significant steps to mitigate the effects of the violation for the affected parties. The immediate actions taken post-incident, including the completion of the Segmentation and Segregation process and the implementation of two-factor authentication, demonstrate a proactive approach to security. Furthermore, the training provided to employees, in collaboration with the Italian Academy of the Internet Code (IAIC), reflects a commitment to enhancing awareness and skills related to security and privacy.

The cooperation with the Authority and the judiciary, along with the measures implemented to address the incident, indicate a serious commitment to compliance with the applicable regulations. The assessment of risks and the subsequent reduction of the gross risk further illustrate the Company’s dedication to improving its security posture.

In light of these considerations, it is recommended that the Company continues to enhance its security measures and training programs, ensuring ongoing compliance with the relevant regulations and standards.

provided sufficient measures to detect the personal data breach in a timely manner. The investigation revealed that "XX 22:02:12 First access from XX made by IP 193.178.169.22 (associated with attackers related to XX) using the account XX" and that the malicious actors carried out a series of preparatory operations for the cyber attack. The analyses conducted by YARIX did not demonstrate adequate measures to ensure timely detection of the breach.

5.2. Insufficient technical and organizational measures to ensure data security

It was noted that the technical and organizational measures implemented by the data controller were

not sufficient to ensure an adequate level of security for personal data, particularly considering the nature of the data processed and the risks involved. The absence of robust security protocols contributed to the vulnerability of the data to unauthorized access and potential breaches.

5.3. Failure to notify the supervisory authority and affected individuals

The investigation also highlighted that the data controller failed to notify the supervisory authority and the affected individuals about the data breach within the stipulated timeframe, as required by Articles 33 and 34 of the Regulation. This delay in notification not only contravened legal obligations but also hindered the ability of affected individuals to take necessary precautions in response to the breach.

6. Recommendations

In light of the findings, it is recommended that the data controller implement immediate corrective actions to address the identified deficiencies. This includes enhancing technical and organizational measures to ensure data security, establishing protocols for timely detection and reporting of data breaches, and ensuring compliance with notification requirements as set forth in the Regulation. Regular audits and assessments should also be conducted to evaluate the effectiveness of the implemented measures and to adapt to evolving security threats.

7. Conclusion

The investigation has revealed significant shortcomings in the data processing activities of the data controller, which have resulted in violations of the Regulation. It is imperative that the necessary steps are taken to rectify these issues and to safeguard the rights and freedoms of the affected individuals. Failure to comply with the recommendations may result in further regulatory actions and penalties as stipulated under the applicable legal framework.

allowed to "trace back the methods used by the attackers to compromise privileged accounts due to the deletion of logs" and "with reference to the firewall logs (traffic and/or VPN), the limited local retention and the absence of useful extractions (regarding some of them) to be carried out close to the event, so as to avoid the rotation of the logs themselves, did not allow the identification of further evidence (VPN accesses or traffic to anomalous IPs)" (see YARIX report). The Company also stated that "there was a system monitoring system but not a control room." These elements did not allow the data controller to promptly identify the personal data breach that occurred. In this regard, it is specified that the arguments formulated by the Company in the submissions regarding the identification of the moment when the controller can be considered aware of the breach and, therefore, from which it is required to notify the Supervisory Authority, pursuant to Article 33 of the Regulation, are not relevant in relation to what is contested in the aforementioned notification act of XX; in fact, the aforementioned aspect was not subject to remarks by the Authority, which did not find, against the Company, an omission or delay in the aforementioned notification of breach, pursuant to Article 33 of the Regulation. What emerged, instead, was the inadequacy of the measures adopted to promptly detect the personal data breach based on anomalous behaviors, detectable from VPN accesses to the corporate network (such as, for example, the time and frequency of accesses, typically at night, their origin from IP addresses of foreign countries, which should have, in any case, been subject to verification) and from the operations carried out with domain accounts with or without administrative privileges (such as, for example, the deactivation of antivirus software on certain systems). The failure to adopt adequate measures to promptly detect personal data breaches does not comply with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation which, in the case at hand, taking into account what is provided by Guidelines No. 9/2022 (and the previous Guidelines on the notification of personal data breaches pursuant to Regulation (EU) 2016/679, adopted on October 3, 2017, Amended and adopted on February 6, 2018. WP250), requires that the controller and the processor must implement measures to "promptly identify [...] a breach."

5.2.2. Failure to adopt adequate measures to ensure the security of networks

During the investigation, it emerged that the Company had not adopted adequate measures to segment and segregate the networks on which the workstations of its employees were located, as well as the systems (servers) used for processing. In fact, as highlighted by the Company during the inspection activities, "the servers of the ASL ex 16 and ex 17 were located on a dedicated VLAN

different from that where the workstations were located, and a new environment was being prepared starting from the 3 Data Centers of the 3 ASLs." In relation to this aspect, the Company, following the incident, deemed it necessary to implement "an environment with multiple isolated VLANs and firewall rules." In this regard, within the analysis activities of YARIX, in relation to the personal data breach in question, it was noted that "this type of threat is countered by implementing so-called defense-in-depth, that is, activating various security measures at different layers of the infrastructure that separate the attacker from administrative access to the entire network. Based on Yarix's experience in technological and organizational cybersecurity, an activity plan can be analyzed to be implemented based on agreed priorities, taking into account the peculiarities of the healthcare sector in which many IT systems are certified by the manufacturer and cannot be modified without losing the warranty of proper functioning" (see annex section, XX to the notification of XX). In this regard, it is highlighted that the fact that, at the time of the incident, the Company had initiated some interventions to strengthen network security, not yet completed due to the processes of unification and separation of the Companies pertaining to the current controller, while deserving consideration in the evaluations regarding the existence or not of a violation of the principle of data protection by design and data protection by default, as per Article 25 of the Regulation, cannot be considered for the purpose of deeming the violation of Article 32 of the Regulation non-existent. The creation of VLANs - being a preparatory measure for effective segregation and segmentation of the networks on which the workstations are located compared to those where the server systems are located - must be accompanied by further measures such as, for example, adequate filtering rules on the firewall systems. Moreover, at the time when the personal data breach occurred, remote access via VPN to the Company's network was carried out through a computer authentication procedure based solely on the use of username and password. In relation to this aspect, the Company specified that "on XX a 'Security Program Document' was approved to enhance security measures and adapt them to the minimum measures of AgID [...] in this document, among others, the measure of two-factor authentication was provided."

****for VPN access**** (see notification of XX, section XX, point XX and minutes of XX, page XX).

On this point, it should be noted that the circumstance that the two-factor authentication constituted - as asserted by the Company in its defense submissions - a measure indicated by the Agid guidelines, which state: "Minimum ICT security measures for public administrations" (Directive of the President of the Council of Ministers August 1, 2015), only for "privileged users and administrative rights," does not exempt, in general, the data controller from the obligation to carry out an assessment, in concrete terms, on the appropriateness of the measures adopted to ensure the security of processing, taking into account the context in which it operates. In particular, the adoption of the measures indicated in the aforementioned guidelines - which also indicate the "minimum security measures for the Italian public administration, keeping in mind the enormous differences in size, mandate, types of information managed, exposure to risk, and other characteristics of the over twenty thousand public administrations" - does not guarantee, by itself, compliance with the obligations regarding the security of processing. The aforementioned guidelines aim to "indicate to public administrations the minimum measures for ICT security that must be adopted in order to counter the most common and frequent threats to which their information systems are subject," starting from "the set of controls known as SANS 20 [...] in version 6.0 of October 2015," and "ensure the minimum level of protection in most situations [...] keeping in mind the enormous differences in size, mandate, types of information managed, exposure to risk, and other characteristics of the over twenty thousand public administrations," recommending that "each administration [...] identify [internally] any subsets, technical and/or organizational, characterized by homogeneity of requirements and security objectives, within which [...] to apply uniformly the measures suitable for achieving those objectives." Specifically, the Guidelines, having been issued based on the state of the art, technical knowledge, and cyber threats present in 2015, could not take into account the worsening of cyber risk in recent years, also due to the spread and adoption, during the COVID-19 pandemic, of methods and technological tools to enable the performance of activities (work-related and otherwise) remotely. This change in scenario, also considering the significant increase in attacks by cybercriminals, would have required, at the end of XX, a renewed assessment that weighed the new and much more serious risks associated with

processing for the rights and freedoms of the data subjects concerning the adequacy of the measures adopted. The aforementioned assessment, which could not be crystallized and, therefore, concluded at the time when the processing was designed, should have been continuously carried out over time, also in light of technological development; this, also in order to develop an awareness regarding the necessity to mitigate the risks arising from personal data breaches, considering, moreover, that the Company made use of two VPNs, from different providers, which both constituted the access point for malicious actors.

The alleged compliance with the measures indicated in the aforementioned Agid Guidelines, therefore, does not exhaust the obligation of the data controller to adopt adequate measures based on its own risk assessment. In fact, the Regulation, in accordance with the principle of accountability, assigns to the controller the task of identifying and adopting appropriate technical and organizational measures to ensure a level of security adequate to the risks presented by the processing, which, in this case, were high due to the nature of the data processed, the large scale of the data subjects, including vulnerable individuals, involved, as well as, in the event of a breach, the possible negative consequences for the data subjects, particularly with regard to the compromise of the confidentiality of health-related data concerning them.

The failure to implement, at the time of the breach, adequate measures to ensure the security of the networks does not appear fully compliant with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation, which, in the case at hand, requires that the controller and the processor must implement measures to “ensure on a permanent basis the confidentiality, integrity, availability, and resilience of processing systems and services” (letter b)).

6. ****Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

The violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, caused by the conduct carried out by the Company, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 4 and 5 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures provided for in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case,” and, in this context, “the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the website.

web of the Guarantor pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019).

In light of the above and, in particular, of the category of personal data affected by the violation, the number of data subjects involved, and the unintentional nature of the violation, as the incident appears to have been caused by malicious behavior on the part of third parties, of which the postal police has been formally notified, it is believed that the level of severity of the violation committed by the Company is high (cf. European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

Having said that, considering certain elements as a whole and, in particular, that:

- the Guarantor became aware of the event following the breach notification made by the Company, pursuant to Article 33 of the Regulation and from several requests received by the Guarantor regarding the incident (Article 83, paragraph 2, letter h), of the Regulation);
- the Company has addressed the issue by introducing a diverse range of measures, some of which were already planned, aimed not only at mitigating the damage suffered by the data subjects but also at reducing the replicability of the event that occurred (Article 83, paragraph 2, letters c) and f) of the Regulation);
- the Company has already been subject to a sanctioning measure in relation to relevant violations (measure XX, No. XXX, web document No. 9899929) (Article 83, paragraph 2, letter e), of the Regulation);

- the data controller has cooperated with the Authority well beyond the obligation provided for by Article 31 of the Regulation at every stage of the investigation, including the inspection phase, in order to remedy the violation and mitigate its possible negative effects (Article 83, paragraph 2, letter f), of the Regulation);

it is deemed appropriate to determine the amount of the administrative fine provided for by Article 83, paragraph 5 of the Regulation, in the amount of €22,000.00 (twenty-two thousand) for the violation of Articles 5 and 32 of the same Regulation, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the Guarantor's website of this measure, provided for by Article 166, paragraph 7 of the Code and Article 16 of the Guarantor's Regulation No. 1/2019, should be applied, also in consideration of the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

ALL OF THE ABOVE CONSIDERED, THE GUARANTOR declares the unlawfulness of the processing of personal data carried out by the ULSS No. 6 Euganea, for the violation of the basic principles of processing referred to in Article 5, paragraph 1, letter f) and the obligations referred to in Article 32 of the Regulation, as stated in the reasoning;

ORDERS

the ULSS No. 6 Euganea, with registered office in Padua, Via Enrico degli Scrovegni, No. 14 – 35131 - C.F./VAT No. 00349050286, to pay the sum of €22,000.00 (twenty-two thousand) as an administrative pecuniary sanction, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, for the violation indicated in this measure; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ORDERS

the aforementioned Company, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €22,000.00 (twenty-two thousand) according to the methods indicated in the attachment, within 30 days from the notification of this measure, under penalty of the adoption of subsequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

the full publication of this measure on the Guarantor's website, pursuant to Article 166, paragraph 7, of the Code, and considers that the conditions for annotation in the internal register of the Authority referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this measure it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the measure itself or within sixty days if the appellant resides abroad.

Rome, July 17, 2024

THE PRESIDENT

Stanzione

THE RAPPOORTEUR

Ghiglia

THE SECRETARY GENERAL

Mattei